

Threat Model

1 PURPOSE AND SCOPE

This threat model identifies security threats to the Smart Asset Inventory and Predictive Maintenance system and links them to controls and security requirements. It covers the React client, backend API, PostgreSQL database, private object storage, scheduled jobs, import process, and optional AI prediction service.

2 SYSTEM ASSETS AND TRUST BOUNDARIES

BOUNDARY OR ASSET	SECURITY CONCERN
Applicationr and API boundary	Authentication, TLS, CORS, CSRF where applicable, input validation, rate limits, and error handling.
Authorization boundary	RBAC, organizational scope, object-level checks, and separation of duties for transfers, retirement, and permission grants.
PostgreSQL database	Least-privilege connections, parameterized queries, backup protection, integrity of lifecycle history, and audit retention.
Private file storage	Authorized upload/download, malware scanning, storage-key protection, short-lived access, and quarantine.
AI prediction service	Input integrity, model/version traceability, access control, human confirmation, and deterministic fallback.
Audit and monitoring boundary	Append-only evidence for critical events, security-event logging, and monitoring of authentication or resource-abuse anomalies.

3 THREAT REGISTER

ASSET OR BOUNDARY	THREAT	RISK	CONTROLS	REQUIREMENTS
User credentials	Account takeover through brute force, token theft, or unsafe reset	High	Rate limit authentication, secure password hashing, short-lived tokens, rotation, revocation, secure reset flows	01-04, 41-43
RBAC and scope	Privilege escalation or cross-college access through missing object checks	Critical	Backend RBAC, object-level authorization, scope grants, deny self-service role/scope changes	05-14, 33, 44
Transfers and retirement	Self-approval, bypassed state transitions, or tampered custody history	Critical	Separate requester and approver, authenticated workflow, append-only history, immutable audit events	15-19, 28-30, 44
Financial records	Unauthorized invoice or purchase-order viewing/modification	High	Separate procurement permissions, backend scope checks, object-level authorization	20-23, 33
Attachments	Malware upload, public-link exposure, path manipulation, unauthorized download	High	Private storage, type/size validation, malware scanning, key validation, short-lived authorization	24-27, 45-46

3 THREAT REGISTER (CONTINUED)

ASSET OR BOUNDARY	THREAT	RISK	CONTROLS	REQUIREMENTS
API endpoints	IDOR, SQL injection, mass assignment, sensitive error disclosure	High	Resource authorization, parameterized queries, allow-list payloads, safe errors	32-36, 47
Web client	Stored/reflected XSS, unsafe CORS, or CSRF with cookie sessions	High	Output encoding, security headers, restrictive CORS, CSRF protection when applicable	47, 49
Asset import and export	Malicious input, CSV formula injection, excessive file size, or data leakage in exports	Medium	Validate imports, neutralize formula-like values, audit exports, authorize data scope	29, 34, 48
Secrets and deployment	Credentials committed to source control or exposed through logs/CI	High	Secret storage, secret rotation, log hygiene, least privilege	04, 31, 50-51
Database and backups	Direct data modification, destructive deletion, backup exposure, or failed recovery	High	Least-privilege DB roles, append-only audit/history controls, protected backups and tested restores	18-19, 30, 51
AI risk predictions	Manipulated inputs, unauthorized viewing, automatic operational action, or unavailable prediction service	High	Traceable inputs, authorized review, human confirmation, model log, deterministic fallback	37-40, 52-53
Availability	Denial of service or resource exhaustion of API, import, or prediction workloads	Medium	Rate limits, size limits, job/resource limits, monitoring and alerting	25, 41, 49

4 PRIMARY ATTACK PATHS

A normal user alters an object identifier in a request to reach another college's invoice, work order, or attachment. Backend object and scope checks must deny the request.

A requester submits a transfer or retirement and attempts to approve it with the same account. The workflow must enforce a distinct authorized approver.

An attacker uploads a harmful or disguised attachment and attempts to retrieve it using a guessed storage URL. The file must remain private, scanned, and accessible only through authorized short-lived access.

An attacker submits unsafe query or update fields through an API or import. Parameterization, allow-listed update fields, and input validation must prevent database manipulation and privilege changes.

A compromised account or AI input attempts to create an automatic maintenance or disposal outcome. Risk outputs must create a review queue only, with an auditable human decision and non-AI fallback.

5 RISK TREATMENT AND VERIFICATION

Critical and high risks must be addressed before release. Each mapped requirement must have a negative test proving that an unauthorized actor, a user from a sibling organizational scope, or a requester attempting self-approval cannot complete the protected action. File, authentication, export, audit, import, and AI controls must also be tested through failure scenarios.

6 RESIDUAL RISK AND OWNERSHIP

AREA	RISK OWNER	RELEASE EVIDENCE
Authentication and API	Backend and Security QA	Expired/revoked token, brute-force, IDOR, injection, and unsafe-update tests pass.
Authorization and workflows	Backend and Product owner	Scope and self-approval tests pass; transfer and retirement histories remain intact.
Files and documents	DevOps and Security QA	Private storage, malware scan, authorized download, and quarantine tests pass.
Database and audit	Backend and DevOps	Least-privilege roles, backup restore, append-only history, and audit-event tests pass.
AI service	Insights and Product owner	Human confirmation, model/version traceability, access control, and fallback demonstration pass.